

Curso de Especialización Ciberseguridad en las TIC

3.1 Auditoría básica de seguridad: Actualizaciones y parches

Objetivos

- Identificar las vulnerabilidades en el subsistema.
- Evaluar las medidas de seguridad actuales del subsistema respecto a las actualizaciones y parches del sistema.
- Proponer mejoras o acciones para reforzar la seguridad del servidor.

Resumen

Autora: Marina del Pilar López Oliva

Enero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	19/01/2026	Documentación del apartado 1 y 2.
1.1	20/01/2026	Documentación del resto de la práctica.

Índice de Contenidos

1. Introducción.....	4
2. Apartado 1.....	4
3. Apartado 2.....	6
4. Apartado 3.....	7
5. Conclusiones.....	8
6. Webgrafía.....	8

1. Introducción

En este apartado vamos a analizar las actualizaciones de seguridad de Microsoft de lo que llevamos del 2026, destacando las vulnerabilidades con CVE asignado y su nivel de gravedad. Es importante conocer estos avisos de seguridad y actuar de inmediato, porque hay fallos que permiten ejecución remota de código, elevación de privilegios y otros riesgos importantes.

Este documento presenta los resultados de la auditoría de seguridad realizada al servidor Windows Server 2025 Datacenter que actúa como controlador de dominio principal. El análisis se basa en datos públicos de vulnerabilidades y evalúa el cumplimiento con buenas prácticas de seguridad.

2. Apartado 1.

Vamos a basar este análisis, en la información proporcionada de CVEDetails. Debemos considerar que estamos en enero de 2026 para realizar un análisis exhaustivo de las vulnerabilidades reportadas para Windows Server 2025 Datacenter. Los datos revelan un panorama de seguridad en evolución que requiere atención inmediata. La figura adjunta resume el total de vulnerabilidades y su distribución por tipo e impacto entre 2024 y 2026.

Vulnerabilities by types/categories

Year	Overflow	Memory Corruption	Sql Injection	XSS	Directory Traversal	File Inclusion	CSRF	XXE	SSRF	Open Redirect	Input Validatic
2024	0	0	0	0	0	0	0	0	0	0	0
2025	97	117	0	0	3	0	0	0	0	0	0
2026	7	14	0	0	1	0	0	0	0	0	0
Total	104	131			4						

Vulnerabilities by impact types

Year	Code Execution	Bypass	Privilege Escalation	Denial of Service	Information Leak
2024	33	0	42	7	6
2025	113	0	15	2	8
2026	7	0	1	0	0
Total	153		58	9	14

Figura 1. Vulnerabilidades de Windows Server 2025 en CVEDetails.

Resultados del análisis realizado:

- Evolución temporal. Se identifica un pico significativo de vulnerabilidades en 2025, coherente con el ciclo de lanzamiento y adopción inicial del Windows Server 2025. Los datos preliminares de 2026 muestran una marcada reducción en el volumen de reportes.
- Tipos de vulnerabilidades dominantes. Las amenazas más prevalentes son:
 - Corrupción de memoria (131): principal vector de ataque.
 - Overflow (104): alto riesgo de explotación.
- Impacto principal. La categoría de mayor gravedad es la ejecución de código, con 153 casos.. Seguida de la elevación de privilegios con 58 casos.

Vulnerabilidades más importantes encontradas en diciembre del 2025:

CVE ID	CVSS	Estado	Impacto
CVE-2025-62221	7.8	Exploited conocido	Ejecución remota de código
CVE-2025-64678	8.8	Activo	Elevación de privilegios
CVE-2025-62549	8.8	Activo	Salto de seguridad
CVE-2025-62456	8.8	Activo	Divulgación de información

Figura 2. CVEs con más puntuación en CVSS en diciembre del 2025.

Vulnerabilidades más importantes detectadas en enero de 2026:

CVE ID	CVSS	Servicio Afectado	Parche disponible
CVE-2026-20868	8.8	Active Directory	KB5022285
CVE-2026-20922	7.8	Remote Desktop	KB5022286
CVE-2026-20856	8.1	SMB Server	KB5022287
CVE-2026-20840	7.8	Windows DNS	KB5022288

Figura 3. CVEs con más puntuación en CVSS en enero del 2026.

Con este análisis hecho podemos ver las vulnerabilidades recientes más críticas. Entre diciembre de 2025 y enero de 2026, se destacan varias con CVSS alto que afectan a componentes centrales como Active Directory, Escritorio Remoto y SMB. Aunque para estas Microsoft ya ha emitido parches de seguridad. El subsistema presenta un perfil de riesgo elevado, principalmente por vulnerabilidades de corrupción de memoria y desbordamiento que permiten ejecución de código. La existencia de exploits activos y vulnerabilidades recientes en servicios críticos exige la aplicación inmediata de las actualizaciones de seguridad disponibles.

3. Apartado 2.

El Windows Server 2025, del subsistema que debemos fortificar, dispone de actualizaciones de seguridad publicadas por Microsoft para las vulnerabilidades más recientes y críticas detectadas. Incluyendo los parches específicos para servicios esenciales como Active Directory, SMB, DNS y Escritorio Remoto.

No obstante, con este análisis revelamos que varias vulnerabilidades con CVSS alto han estado activas durante un periodo de tiempo significativo antes de la aplicación de los parches, lo que supone una ventana de exposición elevada. Algunas de ellas incluso cuentan con exploits conocidos, incrementando el riesgo de compromiso del sistema.

En relación con las buenas prácticas de seguridad informática, se observan las siguientes conclusiones:

- La existencia de parches oficiales indica que el fabricante mantiene un ciclo de actualización adecuado.
- La seguridad del subsistema depende de la rapidez de la aplicación de dichas actualizaciones.
- No se evidencia la existencia de un proceso automatizado y programa de gestión de parches.
- La dependencia de actualizaciones manuales o reactivas no cumple plenamente con las buenas prácticas recomendadas por Microsoft para entornos empresariales y educativos.

En consecuencia, aunque las medidas de actualización disponibles son técnicamente adecuadas, su gestión puede considerarse parcialmente insuficiente si no se garantiza la aplicación inmediata de los parches críticos.

Las medidas técnicas existen pero la gestión es insuficiente. La dependencia de actualizaciones manuales y la ventana de exposición prolongada no cumplen con buenas prácticas empresariales, representando un riesgo significativo para la seguridad del subsistema.

En conclusión, aunque existen parches y mecanismos de actualización adecuados, su gestión no es suficiente. La aplicación tardía de actualizaciones críticas supone un riesgo relevante para la seguridad del subsistema.

4. Apartado 3.

A partir del análisis realizado en los anteriores apartados, se proponen las siguientes mejoras con el objetivo de reducir la superficie de ataque y reforzar la seguridad de nuestro servidor Windows Server 2025 Datacenter que actúa como controlador de dominio de nuestro centro educativo.

Mejora 1. Implementación de una gestión automatizada de parches. Se recomienda implantar un sistema centralizado de gestión de actualizaciones que permita automatizar la descarga, aprobación y despliegue de parches de seguridad críticos. Aquí deberíamos configurar una herramienta de gestión automatizada y establecer una política de aprobación automática para actualizaciones de seguridad con CVSS alto. Las herramientas que podemos utilizar son WSUS, Microsoft Endpoint Configuration Manager, etc.

Mejora 2. Refuerzo de los servicios críticos del sistema. Dado que las vulnerabilidades afectan principalmente a Active Directory, SMB, DNS y Escritorio Remoto, es necesario aplicar un endurecimiento de estos servicios. Para esto deberíamos revisar los servicios activos, limitar el acceso remoto, aplicar directivas de grupo de seguridad y deshabilitar servicios innecesarios. Se podrían deshabilitar los servicios mediante Powershell.

Mejora 3. Mejora de la monitorización y auditoría de seguridad. Para detectar posibles intentos de explotación, debemos reforzar la monitorización del sistema y el registro de eventos de seguridad. Para ello, activamos auditorías avanzadas en Active Directory y deberemos revisar periódicamente los registros de seguridad del sistema. Se podría usar Windows Event Forwarding o SIEM como Graylog.

Mejora 4. Establecimiento de un plan de mantenimiento y revisión periódica. Es fundamental definir un procedimiento regular de revisión de vulnerabilidades y estado de actualizaciones. Tendríamos que programar revisiones mensuales de seguridad y aplicar parches en ventanas de mantenimiento planificadas.

Se recomendaría priorizar la implementación de un sistema automatizado de gestión de parches y realizar un endurecimiento de servicios críticos en el próximo trimestre.

5. Conclusiones

Esta práctica me ha enseñado a realizar un análisis sobre el servidor Windows Server 2025 Datacenter. Lo que me ha permitido identificar un conjunto de vulnerabilidades relevantes que afectan a servicios críticos del sistema. Aunque el fabricante proporciona parches mecanismos de seguridad adecuados, la falta de una gestión automatizada y proactiva de las actualizaciones incrementa el riesgo de explotación. Por eso, la aplicación de las mejoras propuestas resulta fundamental para reforzar la seguridad del subsistema y garantizar un entorno más seguro y estable en el contexto educativo.

6. Webgrafía

<https://www.cvedetails.com/version/1886759/Microsoft-Windows-Server-2025-0.html>

<https://www.catalog.update.microsoft.com/Search.aspx?q=windows%20server%202025>